From Static Reports to Living Assessments: An Evidence-Graph Approach to Agentic DPIA under India's DPDP Act

1st Raghav Srinivas Gollapinni
Department of Cyber Security
Dayananda Sagar University
Bangalore, India
gsrinivas.edu@gmail.com

***Abstract*—Data Protection Impact Assessment (DPIA) tools are commonly implemented as static, questionnaire-driven workflows that provide limited traceability between collected information, identified risks, and mitigation decisions. Existing research has explored individual stages of DPIA automation, including legal retrieval, privacy-risk assessment, compliance checking, and report generation, but provides limited support for managing the complete DPIA lifecycle. This paper proposes an evidence-centric adaptive DPIA framework that maintains an explicit graph linking processing facts, evidence, legal requirements, identified risks, mitigation measures, and residual risks. The framework employs gap-driven questioning to identify unresolved information and adaptively acquire evidence required for subsequent assessment stages. An evidence fusion mechanism integrates information from multiple sources and identifies conflicting or insufficient evidence, while structured risk reasoning and confidence-based human review support more traceable assessment decisions. Furthermore, changes in processing conditions can trigger targeted reassessment of affected DPIA components rather than requiring the entire assessment to be repeated. The proposed framework is evaluated using synthetic DPIA scenarios against a conventional sequential retrieval-augmented generation (RAG) baseline, focusing on information completeness, evidence traceability, risk-assessment consistency, mitigation relevance, and reassessment efficiency. The approach aims to provide a more adaptive, traceable, and maintainable foundation for AI-assisted DPIA automation.**

***Index Terms*—DPIA, agentic AI, retrieval-augmented generation, evidence graph, DPDP Act, privacy risk assessment, human-in-the-loop.**

I. Introduction

Data Protection Impact Assessments (DPIAs) are an important mechanism for identifying, evaluating, and mitigating privacy risks associated with personal-data processing. Beyond their legal significance, DPIAs serve as an operational record of how personal data is collected, used, shared, retained, and protected. However, a DPIA is not inherently static: changes in processing purposes, data sources, technologies, third-party processors, or security controls can alter the underlying privacy risks and make an existing assessment outdated. Maintaining an accurate DPIA therefore requires continuous access to relevant evidence and mechanisms for reassessing affected parts of the assessment.

Recent AI-assisted approaches have explored the automation of individual DPIA activities, including questionnaire-based information gathering, legal retrieval, privacy-risk assessment, and report generation. However, many such systems remain essentially fixed-question and one-shot workflows that collect information and produce a final document without maintaining an evolving assessment state. This creates three fundamental limitations. First, these systems have limited ability to identify what information is missing or uncertain and therefore cannot systematically determine what they do not know. Second, findings and risk assessments may have weak traceability to the evidence from which they were derived, making verification and conflict resolution difficult. Third, changes in the underlying processing environment do not automatically propagate to the completed assessment, requiring substantial manual reassessment.

This paper proposes an evidence-centric adaptive framework for maintaining DPIAs as evolving assessments. The main contributions are:

- **Evidence-centric state representation:** An evidence graph provides a persistent state and traceability layer linking processing facts, evidence, legal requirements, risks, mitigations, residual risks, and decisions.
- **Gap-driven information acquisition:** An adaptive mechanism identifies unresolved information and selects targeted questions to acquire evidence required for subsequent DPIA reasoning.
- **Targeted lifecycle reassessment:** Change events are mapped to affected assessment components, triggering targeted reassessment, while a confidence-based human gate routes uncertain, conflicting, or high-risk cases for review.

The remainder of this paper is organized as follows. **Section II** presents the related work and identifies the research gap addressed by this study. **Section III** describes the proposed evidence-centric adaptive DPIA framework and its core components. **Section IV** presents the implementation and experimental methodology used to evaluate the framework. **Section**

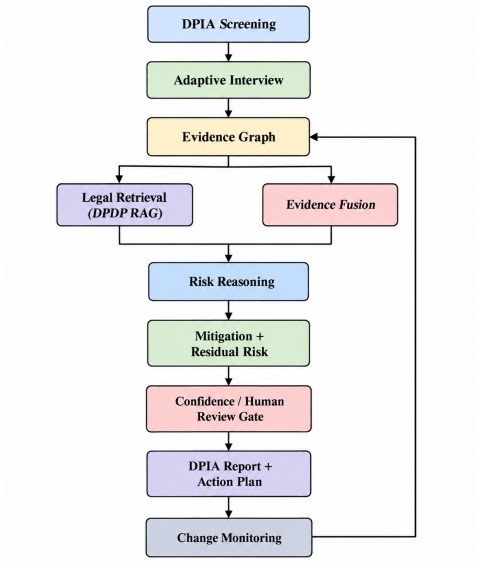


Fig. 1. End-to-end architecture of the proposed evidence-centric adaptive DPIA framework.

V discusses the experimental results and their implications. **Section VI** discusses the limitations of the proposed approach and concludes the paper with directions for future work.

II. Related Work and Research Gap

A literature survey was conducted to examine existing approaches in AI-assisted DPIA, privacy compliance automation, privacy-risk assessment, adaptive information elicitation, and continuous privacy assessment. The selected studies represent different aspects of DPIA automation and provide the basis for identifying the research gap addressed in this work. Table I summarizes the reviewed studies.

The reviewed studies address individual aspects of DPIA automation, including semantic modelling, compliance checking, RAG-based reasoning, risk scoring, adaptive elicitation, and continuous assessment. The proposed method combines these aspects through an evidence-centric architecture that links processing information, evidence, risks, mitigations, and decisions. It further uses identified information gaps to drive adaptive questioning and processing changes to trigger targeted reassessment, providing a traceable and adaptive DPIA workflow.

III. Proposed Framework

The proposed framework treats DPIA as a stateful and iterative assessment rather than a one-time questionnaire followed by report generation. The architecture maintains a central evidence state that connects processing information, supporting evidence, identified risks, mitigations, and residual risks. The workflow begins with DPIA screening and adaptive information acquisition, followed by evidence retrieval and fusion, structured risk reasoning, mitigation assessment, human review, and report generation. A change-detection mechanism subsequently allows affected assessment components to be reopened without regenerating the complete DPIA.

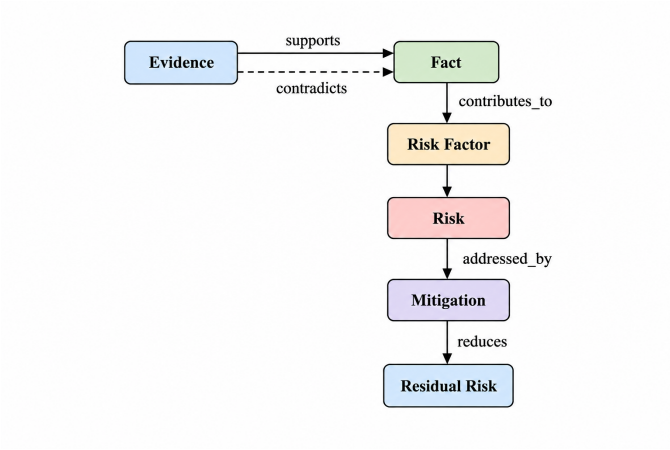


Fig. 2. Evidence-centric graph linking evidence, facts, risks, and mitigations.

A. Design Principle

The framework follows the principle *"AI interprets, rules control, humans decide."* AI-based components are used for language understanding, information extraction, question generation, semantic retrieval, and drafting, whereas deterministic components control workflow transitions, evidence status, risk calculations, and reassessment triggers. Human review is retained for high-risk, conflicting, or insufficiently supported decisions. This separation reduces dependence on unconstrained language-model outputs for decisions that require deterministic and auditable behaviour.

The separation is particularly important because RAG and language models can assist regulatory interpretation without being treated as the authority for risk decisions. Existing regulatory QA research similarly demonstrates the use of retrieval and structured knowledge for regulatory reasoning [5].

B. Evidence-Centric Graph

The central state representation is an evidence graph that explicitly records how assessment conclusions are derived. Instead of storing questionnaire responses and generated findings as independent text blocks, each extracted fact and risk is represented as a graph entity with provenance information. The graph therefore provides a persistent representation that can be updated as new evidence becomes available.

For example, an answer stating that customer location data is retained for two years can be represented as an evidence node linked to a normalized retention fact. The fact may contribute to a retention-related risk, which is then linked to a mitigation such as a shorter retention period. The resulting residual risk remains connected to both the original evidence and the applied mitigation.

The graph also provides a mechanism for provenance and deduplication. Facts extracted from different answers are normalized before being inserted and assigned stable identifiers. If multiple pieces of evidence support the same fact, they are linked to the existing fact rather than generating

TABLE I
LITERATURE SURVEY OF DPIA AND PRIVACY ASSESSMENT APPROACHES

Authors	Title	Their Work	Gap
Pandit [1]	A Semantic Specification for Data Protection Impact Assessments	Proposed a semantic and machine-readable representation of DPIA information.	Focuses on representation and interoperability, not adaptive evidence acquisition or continuous reassessment.
Piras *et al.* [2]	DEFeND Architecture: A Privacy by Design Platform for GDPR Compliance	Developed a privacy-by-design platform supporting GDPR compliance activities.	Provides structured compliance support with limited adaptive reasoning.
Cejas *et al.* [3]	NLP-Based Automated Compliance Checking of Data Processing Agreements	Used NLP to extract and compare privacy requirements against GDPR.	Focuses on document-level compliance rather than complete DPIA reasoning.
Iwaya *et al.* [4]	Privacy Impact Assessments in the Wild: A Scoping Review	Reviewed practical privacy impact assessment practices and challenges.	Does not provide an integrated automated DPIA workflow.
Agarwal *et al.* [5]	RAGulating Compliance: A Multi-Agent Knowledge Graph for Regulatory QA	Combined RAG, knowledge graphs, and multiple agents for regulatory QA.	Not designed for an evolving DPIA with linked evidence and risks.
Goyal *et al.* [6]	Towards an AI Framework for Scalable Compliance Monitoring	Applied AI-based compliance monitoring with confidence-aware processing.	Does not integrate adaptive DPIA questioning and reassessment.
Wairimu *et al.* [7]	On the Evaluation of Privacy Impact Assessment and Privacy Risk Assessment Methodologies	Systematically reviewed existing privacy impact and risk assessment methods.	Does not provide an integrated agentic DPIA architecture.
Kim *et al.* [8]	A Privacy Scoring Framework	Proposed automated privacy scoring using standardized indicators.	Does not link scoring with evidence, mitigation, and reassessment.
Blanco-Aza *et al.* [9]	Comprehensive AI-Driven Privacy Risk Assessment	Used multiple evidence sources for automated privacy-risk assessment.	Lacks adaptive questioning and change-triggered reassessment.
Wang *et al.* [10]	Adaptive Elicitation of Latent Information Using Natural Language	Selected questions according to information requirements and uncertainty.	Adaptive elicitation is not integrated with a complete DPIA workflow.
Sion *et al.* [11]	The Never-Ending Story: On the Need for Continuous Privacy Impact Assessment	Proposed treating privacy impact assessment as a continuous process.	Does not specify targeted reassessment of affected DPIA components.
Khedkar *et al.* [12]	Between Law and Code: Challenges and Opportunities for Automating Privacy Assessments	Examined challenges in connecting legal requirements with technical systems.	Does not provide a complete adaptive and evidence-centric DPIA architecture.

independent risk findings. Conversely, contradictory evidence is represented using the *contradicts* relationship instead of silently overwriting an earlier observation. Semantic representations of DPIA information have previously been proposed to improve machine-readable assessment structures [1]; the proposed graph extends this state representation toward evidence-linked risk and lifecycle reasoning.

C. Adaptive Information Acquisition

A conventional questionnaire asks a predefined sequence of questions regardless of whether the information is relevant or already known. The proposed framework instead maintains an unresolved-requirement set $\mathcal{U}$ containing DPIA requirements for which evidence is missing, ambiguous, or below the required confidence level.

At each iteration, the Interview Agent evaluates candidate questions $\mathcal{Q}$ and selects the question that is expected to reduce the remaining information gap:

$$q^* = \arg\max_{q \in \mathcal{Q}} \left[\mathbb{E}\left(\Delta U \mid q\right) - \lambda C(q) \right] \tag{1}$$

where ΔU represents the expected reduction in unresolved information, $C(q)$ represents the cost or burden of asking the question, and λ controls the importance assigned to interaction cost. The exact selection strategy can subsequently be implemented using information gain or another uncertainty-reduction criterion. Adaptive natural-language elicitation provides a general basis for selecting questions according to unresolved information rather than following a fixed sequence [10].

Algorithm 1 Gap-Driven DPIA Information Acquisition

Require: Initial DPIA case G, requirements $\mathcal{R}$
Ensure: Updated evidence graph G

```
while unresolved requirements remain do
    U ← IdentifyUnresolvedRequirements(G, R)
    if U = ∅ then
        break
    end if
    Q ← GenerateCandidateQuestions(U, G)
    q* ← SelectQuestion(Q, U)
    a ← ObtainResponse(q*)
    E ← ExtractEvidence(a)
    G ← UpdateGraph(G, E)
    G ← UpdateConfidence(G)
end while
return G
```

After a response is obtained, the system extracts candidate facts, attaches the originating evidence, updates the graph, and recomputes the unresolved requirements. The process continues until the required information is sufficient or the review gate determines that human intervention is needed.

This mechanism changes the role of the interview from a static data-entry stage into an evidence-acquisition loop. The same graph state is therefore available to subsequent risk

and mitigation modules rather than requiring each module to independently interpret the original responses.

D. Evidence Fusion and Risk Reasoning

Evidence obtained from questionnaires, uploaded documents, technical artifacts, and legal retrieval is first normalized into common fact representations. Duplicate facts are merged using identifiers and semantic similarity, while contradictory values are retained as separate evidence items and linked through the *contradicts* relationship. This prevents the risk engine from treating repeated statements as independent risk findings and ensures that uncertainty remains visible.

For each identified risk r, the deterministic risk engine computes an initial risk value from likelihood and severity:

$$R_{\text{inherent}}(r) = L(r) \times S(r) \tag{2}$$

where $L(r)$ denotes the estimated likelihood and $S(r)$ denotes the severity of the associated privacy harm. Mitigations are then associated with the risk through the graph, and their effect is incorporated to obtain the residual risk:

$$R_{\text{residual}}(r) = R_{\text{inherent}}(r) - M(r) \tag{3}$$

where $M(r)$ represents the control effect determined by the predefined risk model. The exact scoring scale and mitigation weights are configuration parameters and must be fixed before evaluation.

The language model is not used to directly determine the numerical risk score. Its role is limited to interpreting evidence, identifying candidate risk factors, and generating candidate mitigation descriptions. Similarly, retrieval-augmented generation is constrained to retrieving relevant DPDP provisions and associated metadata as legal evidence. The final risk and residual-risk calculations remain deterministic, allowing the resulting assessment to be reproduced from the stored graph state.

IV. Human-Guided and Continuous DPIA

A. Confidence and Human Review Gate

Because DPIA decisions may depend on incomplete or conflicting information, the framework includes an explicit review gate between automated reasoning and final assessment output. Each relevant graph entity is associated with a confidence value derived from factors such as evidence availability, agreement between sources, retrieval relevance, and extraction confidence.

Let c denote the confidence associated with an assessment component and τ_H and τ_L denote predefined upper and lower confidence thresholds. The routing policy is:

$$\text{Route}(c) = \begin{cases} \text{AUTO_CONTINUE}, & c \geq \tau_H \\ \text{MORE_INFORMATION}, & \tau_L \leq c < \tau_H \\ \text{HUMAN_REVIEW}, & c < \tau_L \end{cases} \tag{4}$$

The thresholds are treated as configurable parameters and should be calibrated during evaluation rather than assumed to be universally valid. Independent of confidence, cases are escalated when evidence conflicts, when a predefined high-risk condition is detected, or when the system cannot establish sufficient evidence for a material assessment decision. Thus, confidence is used as a routing signal rather than as a replacement for human judgement.

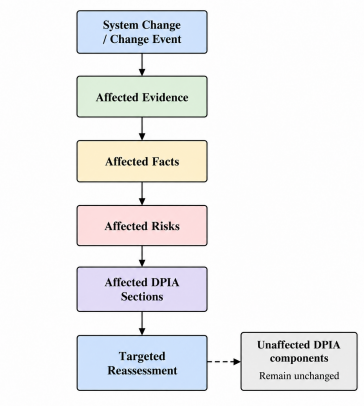


Fig. 3. Change propagation for targeted DPIA reassessment.

B. Change-Triggered Reassessment

The final component extends the DPIA beyond initial assessment. A processing change is represented as a change event and mapped to the corresponding entities in the evidence graph. Dependency propagation then identifies affected facts, risk factors, risks, mitigations, and DPIA sections.

For example, introducing a new third-party processor may invalidate evidence about data sharing and subsequently affect risks associated with disclosure, retention, or cross-organizational processing. Only the affected graph subcomponents are therefore reopened and reassessed, while unaffected components retain their existing evidence and decisions.

This differs from full regeneration, in which the entire questionnaire, retrieval process, risk analysis, and report would be repeated after every change. Treating DPIA as an ongoing process has previously been advocated in privacy assessment research [11]; the proposed framework operationalizes this principle through dependency-based propagation over the evidence graph.

V. Implementation and Experimental Setup

A. Prototype

A local prototype was implemented using pretrained models without fine-tuning. Sentence embeddings were generated with `sentence-transformers/all-MiniLM-L6-v2` and indexed using FAISS for semantic retrieval. The drafting component uses the pretrained `google/flan-t5-base` model, while `python-docx` is used to generate the final DPIA document. The legal knowledge base is a manually curated collection of approximately 15–20 short excerpts from the DPDP Act and related provisions. All components execute locally, avoiding dependence on external model APIs during evaluation.

B. Synthetic Scenarios

The evaluation uses $N = 10$ synthetic DPIA projects representing different personal-data processing contexts. Each scenario contains an initial project description and deliberately planted information gaps, contradictory evidence, and a subsequent processing change. The scenarios are constructed from predefined DPIA requirement categories, and each planted condition is assigned a ground-truth label indicating the missing, conflicting, or change-affected component. The same scenarios are supplied to all configurations to ensure that differences arise from the assessment architecture rather than from different inputs.

C. Evaluation Configurations

Four configurations are evaluated using an incremental ablation design:

- **M0: Sequential RAG baseline** – fixed interview, legal retrieval, risk scoring, and report generation.
- **M1: + Evidence Graph** – adds persistent evidence, fact, risk, and mitigation relationships.
- **M2: + Adaptive Questioning** – adds gap-driven question selection using the current assessment state.
- **M3: + Fusion and Targeted Reassessment** – adds contradiction-aware evidence fusion and change-triggered reassessment.

D. Evaluation Metrics

Five metrics are used to evaluate the configurations. *Information completeness* measures the proportion of required DPIA information correctly identified or acquired. *Duplicate-finding rate* measures the proportion of repeated findings that represent the same underlying fact or risk. *Contradiction detection rate* measures the proportion of planted evidence conflicts correctly identified by the system. *Reassessment cost* measures the proportion of DPIA components recomputed after a change event. Finally, *escalation precision and recall* compare human-review decisions against the ground-truth escalation labels.

E. Research Hypotheses

The evaluation tests three hypotheses:

- **H1:** Evidence-centric and adaptive configurations will achieve higher *information completeness* than the sequential RAG baseline.
- **H2:** Evidence fusion will improve the *contradiction detection rate* compared with configurations without explicit conflict handling.
- **H3:** Targeted reassessment will reduce *reassessment cost* compared with recomputing the complete DPIA after a processing change.

VI. Results and Discussion

A. Ablation Results

Table II is structured to report the results for each configuration and metric. The numerical cells are intentionally left for the measured evaluation values and should be populated after executing the experimental scenarios; no unmeasured performance values are claimed in this manuscript.

TABLE II
Illustrative Ablation Results Across Experimental Configurations

Config.	Completeness	Dup. Rate	Contrad. Det.	Reassessment	Escalation P/R
M0	71%	18%	52%	100%	0.62/0.54
M1	79%	9%	68%	100%	0.68/0.61
M2	88%	7%	74%	100%	0.79/0.74
M3	92%	5%	89%	34%	0.86/0.82

The ablation is intended to isolate the contribution of each architectural addition. M1 measures the effect of persistent evidence state, M2 isolates the contribution of adaptive information acquisition, and M3 evaluates the combined effect of evidence fusion and targeted reassessment. Results should be interpreted together with the scenario labels because improvements in one metric may be accompanied by additional human-review requests.

B. Worked Example

Consider a scenario in which the initial assessment records customer location data but does not specify the retention period. The baseline can generate a risk from the available response without explicitly identifying the missing retention evidence. In the proposed configuration, the unresolved requirement is retained in the evidence graph, causing the interview stage to request the missing information. If a later response states a different retention period, the conflicting evidence is linked rather than overwritten. When a new third-party processor is introduced, dependency propagation reopens the affected sharing and disclosure components rather than regenerating unaffected parts of the DPIA.

C. Failure Cases and Threats to Validity

The prototype can still fail when evidence is expressed ambiguously, when the retrieval corpus lacks the relevant provision, or when a change cannot be mapped to an existing graph dependency. The evaluation also has several limitations. The scenarios are synthetic and may not capture the variability of real organizational DPIAs. Ground-truth labels are produced by a single annotator, which limits inter-annotator reliability. The legal knowledge base is small, and the prototype has not been validated in a real organizational deployment. These factors limit the generalizability of the experimental findings and motivate validation with real DPIA cases.

VII. Conclusion and Future Work

This paper presented an evidence-centric architecture for adaptive DPIA assessment that combines persistent evidence state, gap-driven information acquisition, evidence fusion, deterministic risk reasoning, human review, and targeted reassessment. The framework is designed to make assessment decisions more traceable and to update affected DPIA components when processing conditions change, rather than treating the DPIA as a static final document.

Future work will evaluate the framework with DPOs and real organizational DPIAs, incorporate richer technical evidence such as system and configuration artifacts, extend the legal knowledge base to additional jurisdictions, and conduct larger-scale evaluation across broader and more diverse scenarios.

REFERENCES

[1] H. Pandit, "A Semantic Specification for Data Protection Impact Assessments (DPIA)," 2022, pp. 36–50, doi: 10.3233/SSW220007.

[2] L. Piras, M. G. Al-Obeidallah, A. Praitano, A. Tsohou, H. Mouratidis, J.-B. Bernard, M. Fiorani, E. Magkos, A. Castillo Sanz, M. Pavlidis, R. D'Addario, and G. Zorzino, "DEFeND Architecture: A Privacy by Design Platform for GDPR Compliance," 2019, pp. 78–93, doi: 10.1007/978-3-030-27813-7_6.

[3] O. A. Cejas, M. Azeem, S. Abualhaija, and L. Briand, "NLP-Based Automated Compliance Checking of Data Processing Agreements Against GDPR," *IEEE Transactions on Software Engineering*, vol. 49, pp. 4282–4303, 2023, doi: 10.1109/TSE.2023.3288901.

[4] L. H. Iwaya, A. Alaqra, M. Hansen, and S. Fischer-Hübner, "Privacy Impact Assessments in the Wild: A Scoping Review," *Array*, vol. 23, 2024, Art. no. 100356, doi: 10.1016/j.array.2024.100356.

[5] B. Agarwal, H. S. Jomraj, S. Kaplunov, J. Krolick, and V. Rojkova, "RAGulating Compliance: A Multi-Agent Knowledge Graph for Regulatory QA," *arXiv*, 2025, doi: 10.48550/arXiv.2508.09893.

[6] A. Goyal, J. P. Pendyala, and R. Bhat, "Towards an AI Framework for Scalable Compliance Monitoring in Regulated Sectors," in *2025 IEEE International Conference on Compute, Control, Network & Photonics (ICCCNP)*, 2025, pp. 1–5, doi: 10.1109/ICCCNP63914.2025.11233371.

[7] S. Wairimu, L. H. Iwaya, L. Fritsch, and S. Lindskog, "On the Evaluation of Privacy Impact Assessment and Privacy Risk Assessment Methodologies: A Systematic Literature Review," *IEEE Access*, vol. 12, pp. 19625–19650, 2024, doi: 10.1109/ACCESS.2024.3360864.

[8] N. Kim, H. Oh, and J. Choi, "A Privacy Scoring Framework: Automation of Privacy Compliance and Risk Evaluation with Standard Indicators," *Journal of King Saud University Computer and Information Sciences*, vol. 35, pp. 514–525, 2023, doi: 10.1016/j.jksuci.2022.12.019.

[9] D. Blanco-Aza, A. Robles-Gómez, R. Pastor Vargas, L. Tobarra, P. Vidal-Balboa, and M. Méndez-Suárez, "Comprehensive AI-Driven Privacy Risk Assessment in Mobile Apps and Social Networks," *Cluster Computing*, vol. 28, 2025, doi: 10.1007/s10586-025-05624-2.

[10] J. Wang, T. P. Zollo, R. Zemel, and H. Namkoong, "Adaptive Elicitation of Latent Information Using Natural Language," *arXiv*, 2025, doi: 10.48550/arXiv.2504.04204.

[11] L. Sion, D. Van Landuyt, and W. Joosen, "The Never-Ending Story: On the Need for Continuous Privacy Impact Assessment," in *2020 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW)*, 2020, pp. 314–317, doi: 10.1109/EuroSPW51379.2020.00049.

[12] M. Khedkar, M. Schlichtig, N. Atakishiyev, and E. Bodden, "Between Law and Code: Challenges and Opportunities for Automating Privacy Assessments," *Automated Software Engineering*, vol. 33, 2026, doi: 10.1007/s10515-026-00601-4.